

TriMerge Comply

User & Administration Manual

Version	1.0.0
Release Date	June 24, 2026
Platform	REST API / Cloud
Classification	CONFIDENTIAL
Prepared For	TriMerge Consulting — Internal Use

This document contains confidential and proprietary information belonging to TriMerge Consulting. It is intended solely for authorised personnel involved in the implementation, administration, and use of the TriMerge Comply platform. Unauthorised reproduction, distribution, or disclosure is strictly prohibited.

1 Executive Summary

TriMerge Comply is a cloud-native HR compliance and audit management platform built by TriMerge Consulting. It enables HR teams, engagement directors, and compliance analysts to manage the full lifecycle of workforce audits — from adverse impact screening and pay equity analysis through to formal findings, evidence collection, and client-ready PDF reporting.

The platform automates the labour-intensive steps of compliance auditing: statistical analysis of applicant flow data, AI-assisted pay equity gap detection, position description review against government standards, and findings documentation with governance controls that prevent unevidenced conclusions from being approved.

Role	Audience
Platform Admin	TriMerge system administrators managing users and organization settings
Engagement Director	Senior client-facing staff who approve findings and control audit deletion
Project Manager	Mid-level staff overseeing audit progress and analyst assignments
Analyst	HR compliance analysts performing day-to-day audit and analysis work
SME Reviewer	Subject-matter experts validating flags and reviewing findings
Client Read-Only	External clients with read-only access to their audit data

- Multi-tenancy: complete data isolation per organisation via UUID-based scoping
- Adverse impact analysis: Four-Fifths Rule, Chi-Square, Fisher's Exact statistical tests on CSV applicant flow data
- Pay equity analysis: OLS regression gap detection across departments and demographic groups from CSV/Excel/PDF/DOCX
- Position description review: AI-powered compliance checking against government job-posting standards
- Handbook indexing: full-text chunking and semantic search used to ground AI-drafted finding criteria
- Findings management: status machine (new → under review → approved / rejected → closed) with governance gate
- Evidence sub-resource: text notes and Cloudinary-hosted file uploads (PDF, Word, Excel, CSV, images)
- Audit deletion workflow: two-path deletion with mandatory notes and director approval for lower roles
- Comprehensive audit trail: ActivityLog captures every material action across all modules
- PDF report generation: branded Findings Register, Pay Equity Report, and Position Document Report
- CSV exports: dashboard summary, audit list, and flag data

2 System Overview

TriMerge Comply is a RESTful API backend deployed on Render. All client interactions — whether from a web frontend, mobile app, or the Swagger UI — occur over HTTPS via JSON requests to versioned API endpoints. The platform is designed as a multi-tenant service where each organisation's data is isolated by a unique **organizationId** UUID assigned at signup.

The system follows a layered MVC architecture:

Layer	Components	Purpose
Routing	Express Router per module	URL dispatch, role-guard middleware application
Middleware	auth.middleware, validate.middleware, error.middleware	Authentication, input validation, centralised error handling
Controllers	One controller per module	Business logic, request/response shaping
Services	AI, analytics, pay equity, position, storage, email, findings	Reusable domain logic decoupled from HTTP layer
Models	Mongoose schemas (11 models)	Data validation and MongoDB interaction
Database	MongoDB Atlas	Document storage with compound indexes
Storage	Cloudinary	Binary file storage (handbooks, position docs, pay equity files, evidence)

Module	Description
Authentication	Signup, OTP verification, login, token refresh, password management, profile
Audit Management	Create/read/update/delete audits, CSV export, Findings Register PDF
Adverse Impact Analysis	CSV upload, Four-Fifths Rule + statistical tests, flag generation
Flags	Triage, assign, decide (dismiss/review) adverse impact flags
Findings	Formal compliance findings linked to audits and flags, AI-drafted criteria
Evidence	Text and file evidence attached to findings, Cloudinary uploads
Pay Equity Analysis	Multi-format upload, OLS regression gap analysis, AI advisory PDF report
Position Documents	Upload and AI-review of job descriptions against government standards
Handbooks	Policy document indexing used to ground AI finding drafts
Dashboard	KPI summary (audit counts, flag severity, risk levels), CSV export
Activity Log	Immutable event trail across all modules

Module	Description
Audit Deletion Workflow	Two-path deletion: direct (director/admin) or approval-routed (analyst/manager/reviewer)

3 Technology Stack

Category	Technology	Purpose
Runtime	Node.js v24	Server-side JavaScript runtime
Framework	Express 4.x	HTTP routing and middleware pipeline
Database	MongoDB Atlas (via Mongoose 9)	Primary document store with multi-tenant isolation
Authentication	JSON Web Tokens (jsonwebtoken)	Stateless access tokens (15 min) + hashed refresh tokens
OTP / Email	Mailgun + mailgun.js	Email verification and password-change OTP delivery
File Storage	Cloudinary	Binary file hosting for handbooks, position docs, pay equity files, evidence
AI / LLM	OpenAI GPT (openai.service)	Finding draft criteria, pay equity recommendations, position review
PDF Generation	PDFKit (pdfkit)	Server-side PDF rendering for all report types
Document Parsing	mammoth (DOCX), pdf-parse (PDF), xlsx (Excel)	Text extraction from uploaded compliance documents
Security	helmet, express-mongo-sanitize, hpp, express-rate-limit	HTTP headers, injection protection, rate limiting
Hosting	Render (backend branch)	Cloud deployment platform
API Docs	Swagger UI (swagger-ui-express)	Interactive API documentation at /api/docs
Password Hashing	bcryptjs	bcrypt with configurable rounds (default: 10)

Environment Variables Required

MONGODB_URI · JWT_SECRET · JWT_REFRESH_SECRET · CLOUDINARY_URL ·
 OPENAI_API_KEY (optional — AI features degrade gracefully) · MAILGUN_API_KEY ·
 MAILGUN_DOMAIN · MAILGUN_SENDER · CORS_ORIGIN · BCrypt_ROUNDS · NODE_ENV

4 User Roles & Permissions

TriMerge Comply enforces role-based access control (RBAC) across all endpoints. Every authenticated request is checked against the role attached to the user's account. Roles are assigned at registration (default: **viewer**) and can be changed by an **admin** scoped to the same organisation.

Role Key	Display Name	Description
admin	Platform Admin	Full access. Manage users, assign roles, direct-delete audits, view all deletion requests in the org.
director	Engagement Director	Approve or reject audit deletion requests routed to them. Direct-delete their own audits. View all org data.
manager	Project Manager	Create audits, upload analyses, assign flags to analysts, route deletion requests. Cannot approve findings.
analyst	Analyst	Primary workhorse role. Create audits, upload all analysis types, create findings, add/delete their own evidence.
reviewer	SME Reviewer	Review and decide on flags. Read findings and evidence. Route deletion requests. Cannot create audits.
viewer	Client Read-Only	Read-only access to audits, flags, and findings. Cannot create, edit, or delete anything.

✓ = permitted — = not permitted **Own** = only their own records

Action	Admin	Director	Manager	Analyst	Reviewer	Viewer
Create audit	✓	✓	✓	✓	—	—
View audits	✓	✓	✓	✓	✓	✓
Update audit	✓	✓	✓	Own	—	—
Direct delete audit	✓	✓	—	—	—	—
Route deletion request	—	—	✓	✓	✓	—
Review deletion request	—	✓	—	—	—	—
View deletion requests	✓	Own	—	—	—	—
Upload CSV (adv. impact)	✓	✓	✓	✓	—	—
View flags	✓	✓	✓	✓	✓	✓
Decide flag	✓	✓	✓	✓	✓	—
Assign flag	✓	✓	✓	—	—	—
Create finding	✓	✓	✓	✓	—	—

Action	Admin	Director	Manager	Analyst	Reviewer	Viewer
View findings	✓	✓	✓	✓	✓	✓
Update finding	✓	✓	✓	✓	✓	—
Advance finding status	✓	✓	✓	✓	✓	—
Add text evidence	✓	✓	✓	✓	—	—
Upload file evidence	✓	✓	✓	✓	—	—
Delete evidence	✓	✓	✓	Own	—	—
Upload pay equity	✓	✓	✓	✓	—	—
Upload position doc	✓	✓	✓	✓	—	—
Upload handbook	✓	✓	✓	✓	—	—
Delete handbook	✓	✓	—	—	—	—
View dashboard	✓	✓	✓	✓	✓	✓
Export dashboard CSV	✓	✓	✓	✓	—	—
Manage user roles	✓	—	—	—	—	—
View all org users	✓	✓	✓	✓	✓	✓

5 Authentication & Account Management

New accounts are created via the signup endpoint. The following fields are accepted:

Field	Required	Notes
name	Yes	Display name shown throughout the platform
email	Yes	Unique, lowercased. Becomes the login username
password	Yes	Minimum 8 characters. bcrypt-hashed before storage
companyName	No	Used to assign organizationId. Users with matching company names are grouped into the same org
phone	No	Optional contact number

After signup, the system:

1. Creates the user with **isVerified = false** and default role **viewer**
2. Generates a 6-digit OTP and hashes it with bcrypt before storage
3. Sends the OTP to the user's email via Mailgun (purpose: email_verification)
4. The user submits the OTP to **POST /api/auth/verify-otp** — on success, isVerified is set to true
5. The user may now log in

OTP Security Policy

OTP validity: 10 minutes · Max attempts: 5 · Cooldown between resends: 60 seconds · Verification purpose is stored and checked — an email OTP cannot be used for password change.

Authentication uses a dual-token scheme. On successful login the API returns an **access token** (short-lived, 15 minutes) and a **refresh token** (longer-lived). The refresh token is SHA-256 hashed before being stored in the database; the raw value is returned to the client and never stored in plain text.

Token	Lifetime	Usage
Access Token (JWT)	15 minutes	Sent in Authorization: Bearer header on every API request
Refresh Token	Configurable (JWT_REFRESH_SECRET)	POST /api/auth/refresh-tokens to obtain new token pair

Account Lockout: After 5 consecutive failed login attempts, the account is locked for 15 minutes. The remaining wait time is returned in the error response.

The platform provides two password reset paths:

1. User submits their email to **POST /api/auth/forgot-password**
2. A cryptographically secure token is generated, SHA-256 hashed, and stored with a 1-hour expiry
3. A reset link containing the raw token is emailed via Mailgun

4. User submits the raw token + new password to **POST /api/auth/reset-password**
5. On success, the token and all refresh sessions are invalidated
1. Authenticated user submits old + new password to **POST /api/auth/change-password**
2. The system verifies the old password, then hashes and stores the new password as pending
3. An OTP is sent to the user's email (purpose: password_change)
4. User confirms with OTP via **POST /api/auth/verify-change-password**
5. On success, the pending hash is promoted, and all active sessions are invalidated

Endpoint	Action
GET /api/auth/me	Retrieve current user profile (excludes all sensitive fields)
PATCH /api/auth/change-name	Update display name
GET /api/auth/users	List all users in the same organisation (all authenticated roles)
PATCH /api/auth/users/:id/role	Change another user's role — admin only, same org

6 Application Modules

The dashboard provides an organisation-scoped KPI summary aggregated in real time from audits and flags.

Metric	Description
Total Audits	Count of all audits in the organisation
Audits by Status	Breakdown: draft, processing, completed, flagged
Total Flags	Count of all adverse impact flags across all analyses
Flags by Severity	Breakdown: low, medium, high, critical
Flags by Status	Breakdown: open, reviewed, dismissed
Overall Risk	Highest severity level across all open flags
Audit Risk Summaries	Per-audit flag counts, severity breakdown, and calculated risk level
Recent Audits	5 most recently created audits with creator details
Recent Flags	5 most recently generated flags with audit name

- **Export:** GET /api/dashboard/export — downloads a CSV with all audits and all flags in a single file

Audits are the top-level container for all compliance work. Each audit belongs to an organisation and can have associated flags, findings, and a generated PDF Findings Register.

Field	Description
name	Audit name (required, max 100 chars)
description	Optional narrative description (max 500 chars)
organization	Organisation or department being audited
clientName	Client name for the engagement
auditType	Type classification (e.g. Adverse Impact, Pay Equity)
status	draft processing completed flagged

Key operations:

- Create: POST /api/audits — analyst and above
- List: GET /api/audits — filter by clientName, auditType, auditName, status
- Export: GET /api/audits/export — CSV of all audits matching filters
- Findings Register PDF: GET /api/audits/:id/report — branded PDF with cover page, KPI summary, and one block per finding
- Update: PATCH /api/audits/:id — analysts can only update audits they created
- Delete: see Section 7.2 — Audit Deletion Approval Workflow

Upload applicant flow data in CSV format to run automated adverse impact screening. The system applies the **Four-Fifths Rule** (EEOC Uniform Guidelines) and optionally Chi-Square and Fisher's Exact tests. Flags are automatically generated for groups where the impact ratio falls below 0.80.

Required CSV columns:

- group — Demographic group name (e.g. Female, Hispanic)
- selected — Number of applicants selected
- total — Total applicants in that group

Statistical tests performed:

Test	When Applied	What It Measures
Four-Fifths Rule	Always	Impact ratio = group selection rate / highest group rate. Flagged if < 0.80
Chi-Square	When sample sizes are sufficient	Statistical significance of selection rate differences
Fisher's Exact	Small sample sizes	Exact probability of observed selection rates under null hypothesis

Flag severity is assigned based on the impact ratio and statistical test results: **critical** (ratio < 0.60), **high** (0.60–0.69), **medium** (0.70–0.79), **low** (≥ 0.80 but still statistically significant).

Flags represent individual adverse impact violations detected by statistical analysis. Each flag is scoped to an organisation and can be linked to either a specific audit or a standalone CSV upload.

Field	Description
severity	low medium high critical — calculated from impact ratio
status	open (default) reviewed dismissed
group	The demographic group that was flagged
referenceGroup	The highest-selecting group used as the comparison benchmark
selectionRate	Fraction selected within the group
impactRatio	group rate ÷ reference group rate (below 0.80 triggers a flag)
testType	four_fifths fisher_exact chi_square adverse_impact
pValue	Statistical significance value from Chi-Square or Fisher's Exact test
assignedTo	Optional: analyst assigned to investigate this flag

Key operations:

- Decide: POST /api/flags/:id/decide — submit a decision (reviewed or dismissed) with notes
- Assign: PATCH /api/flags/:id/assign — manager+ assigns a flag to an analyst for investigation
- View: GET /api/flags — list with filters by severity, status, auditId

Findings are formal compliance investigation records created by analysts. They represent a documented conclusion drawn from statistical data, interview notes, policy research, and other evidence. A finding cannot be approved without attached evidence, populated criteria, and a populated recommendation.

From Status	To Status	Who Can Transition
new	under_review	Any (analyst, manager, director, admin, reviewer)
under_review	additional_info_required	Any
under_review	approved	Any — but governance gate blocks without evidence + criteria + recommendation
under_review	rejected	Any
additional_info_required	under_review	Any
approved	closed	Any
rejected	closed	Any

Governance Gate

Moving a finding to 'approved' is blocked unless: (1) the criteria field is non-empty, (2) the recommendation field is non-empty, and (3) at least one evidence item is attached. This is enforced server-side and cannot be bypassed.

AI Draft Generation: When a finding is created with `OPENAI_API_KEY` configured, the system automatically drafts the **criteria** and **recommendation** fields using the observation text, risk level, and relevant handbook excerpts retrieved via semantic search. If `OPENAI_API_KEY` is absent, the fields default to empty and the analyst fills them manually. The **POST** `/api/findings/:id/regenerate-draft` endpoint re-runs this draft at any time.

Auto-Evidence from Flags: When a finding is created with a **flagId**, the system automatically creates a **statistical_result** evidence item containing the flag's full statistical data (impact ratio, selection rates, p-value, test type, etc.). This satisfies the governance gate requirement immediately for flag-linked findings.

findingId alias: Every finding response includes both `_id` and a **findingId** alias (equal to `_id`) to make it easy to copy the correct value into evidence sub-resource URLs.

Evidence items are attached to a specific finding and represent the proof that supports the finding's conclusion. Evidence can be text-based or file-backed (hosted on Cloudinary).

Evidence Type	Description	Typical Source
statistical_result	Quantitative analysis output — impact ratios, p-values, regression gaps	Auto-generated from flag or pay equity analysis
interview_note	Notes from a structured interview; includes interviewee name and date	Manual entry by analyst

Evidence Type	Description	Typical Source
policy_excerpt	Text excerpt from an HR policy, handbook, or regulation	Manual entry or handbook search
data_extract	Raw data table or extract from HR systems	Manual entry
observation_note	Field notes from a process walkthrough or observation	Manual entry
document	Uploaded file (PDF, Word, Excel, CSV, PNG, JPEG — max 10 MB)	File upload

File Upload: POST /api/findings/:findingId/evidence/upload — send as multipart/form-data with a **file** field. Metadata (title, type, description, content) are passed as URL query parameters. Maximum file size: 10 MB.

Lock Rule: Evidence cannot be added or deleted on findings with status **approved** or **closed**.

Delete Rule: Analysts may only delete evidence they created. Manager and above can delete any.

Upload compensation data in CSV, Excel (.xlsx/.xls), PDF, or DOCX format. The system extracts tabular data and runs OLS (Ordinary Least Squares) regression to identify statistically significant pay gaps across departments and demographic groups, controlling for legitimate compensable factors.

Required columns in the underlying data:

- Employee identifier (e.g. employee_id)
- Salary / compensation figure
- Demographic group (e.g. gender, race/ethnicity)
- Department or job group

The analysis produces a **Pay Equity Report PDF** (GET /api/payequity/:id/report) that includes an executive summary, plain-language interpretation, key insights, and recommendations. If OPENAI_API_KEY is configured, these sections are AI-generated; otherwise, the system falls back to rule-based text.

Upload job descriptions (PDF, DOCX, TXT, CSV) to receive an AI-powered compliance review against government job-posting standards (based on OFCCP and EEOC requirements).

Review Status	Meaning
not_reviewed	Uploaded but not yet assessed
in_review	Currently being evaluated by an analyst
approved	Meets compliance standards
needs_changes	Non-compliant — specific issues identified
dismissed	Excluded from further review

A **Standards Review** can be triggered separately (POST /api/position/:id/standards-review) to run a detailed checklist-style AI analysis comparing the document against the government standard. A PDF report is available at GET /api/position/:id/report.

Upload company handbooks (PDF or DOCX) to make policy content available to the AI when it drafts finding criteria. The system extracts full text and splits it into 400-word overlapping chunks stored in MongoDB. When a finding is created, the AI searches these chunks semantically to retrieve relevant policy excerpts that ground the criteria draft.

- Upload: POST /api/handbooks/upload — optionally set display name via x-handbook-name header or ?name= query param
- List: GET /api/handbooks — returns all handbooks (chunk data excluded for performance)
- Delete: DELETE /api/handbooks/:id — director and admin only; logs the deletion in ActivityLog

7 Workflow Documentation

The standard audit engagement follows this sequence:

Responsible Role	Step	System Action
Analyst / Manager	Create Audit	POST /api/audits with name, clientName, auditType
Analyst	Upload Adverse Impact CSV	POST /api/upload/csv — flags auto-generated on success
Analyst / Reviewer	Triage Flags	Review each flag: decide (reviewed/dismissed) or assign to analyst
Analyst	Create Findings	POST /api/findings — link flagId for auto-evidence; AI drafts criteria
Analyst	Collect Evidence	Add text evidence and upload supporting documents to each finding
Analyst	Submit for Review	PATCH /api/findings/:id/status → under_review
Director / Manager	Review Finding	Verify criteria, recommendation, and evidence are complete
Director	Approve Finding	PATCH status → approved (governance gate enforced server-side)
Analyst / Director	Generate Report	GET /api/audits/:id/report — branded PDF Findings Register
Analyst / Manager	Close	PATCH status → closed on each approved or rejected finding

Deleting an audit is an irreversible action with a two-path approval mechanism designed to ensure compliance accountability:

1. Director or admin sends DELETE /api/audits/:id with mandatory **deletionNotes** (minimum 10 characters)
2. Audit is immediately deleted
3. ActivityLog entry created with action **audit_deleted**, deletedVia: 'direct', and the notes
1. Requester calls **GET /api/users/directors** to obtain the list of available Engagement Directors
2. Requester submits POST /api/audits/:id/deletion-request with **deletionNotes** and selected **directorId**
3. System validates: notes ≥ 10 chars, directorId is a real director in the org, no pending request already exists
4. An **AuditDeletionRequest** record is created with status **pending**; an audit snapshot is preserved for compliance
5. ActivityLog entry created with action **deletion_requested** including routing details
6. Director views pending requests: GET /api/audits/deletion-requests (directors see only their own requests)
7. Director submits PATCH /api/audits/deletion-requests/:requestId/review with **decision** (approved/rejected) and mandatory **approvalNotes**

8. If approved: audit is deleted and two ActivityLog entries are created (deletion_approved + audit_deleted)
9. If rejected: audit is preserved; ActivityLog entry created with action **deletion_rejected**
10. Duplicate pending requests for the same audit are blocked (HTTP 409)

The findings lifecycle enforces an evidence-before-approval principle:

1. Analyst creates finding (POST /api/findings) — AI drafts criteria and recommendation if configured
2. If flagId provided: statistical_result evidence auto-attached; governance gate is immediately satisfiable
3. Analyst reviews AI draft, edits criteria and recommendation as needed
4. Analyst adds supplemental evidence: interview notes, policy excerpts, data extracts, or file uploads
5. Analyst advances status to **under_review**
6. Reviewer / Director verifies all three governance gate conditions are met (evidence, criteria, recommendation)
7. Director approves — gate checks run server-side on every approval attempt
8. Finding locked: no evidence can be added or removed after approval
9. Finding can subsequently be closed

When CSV adverse impact data is uploaded, flags are automatically created for each violating group:

1. Manager or above assigns flag to analyst: PATCH /api/flags/:id/assign
2. Analyst investigates: reviews statistical results, applicant flow data, and any related findings
3. Analyst (or reviewer) decides: POST /api/flags/:id/decide with status **reviewed** or **dismissed** and decision notes
4. If reviewed: analyst typically creates a formal Finding linked to this flag
5. If dismissed: flag is closed with documented rationale; ActivityLog records the decision
6. Dashboard flag counters update in real time

8 Reporting & Exports

Report / Export	Endpoint	Format	Access
Findings Register PDF	GET /api/audits/:id/report	PDF	analyst+
Pay Equity Report PDF	GET /api/payequity/:id/report	PDF	analyst+
Position Review PDF	GET /api/position/:id/report	PDF	analyst+
Dashboard Export	GET /api/dashboard/export	CSV	analyst+
Audit List Export	GET /api/audits/export	CSV	analyst+

Generated on demand for any audit. Contains: branded cover page with audit metadata, a KPI summary table (total findings, breakdown by status and risk level), and one detailed block per finding showing observation, risk level, criteria, recommendation, assigned reviewer, and handbook reference. Findings are sorted by risk level (critical first) then creation date.

Generated on demand for any pay equity analysis. Contains: executive summary, plain-language interpretation, key insights, flagged pay gaps by department and demographic group, OLS model parameters, and recommendations. AI-enhanced content is generated via OpenAI if available; rule-based fallback text is used otherwise.

Generated on demand for any uploaded position document. Contains: document metadata, AI analysis summary, compliance findings, and recommendations. Includes company name on the cover when available.

9 Troubleshooting Guide

Issue: 401 Unauthorized on all requests

Cause: Access token has expired (15-minute TTL)

Resolution: Call POST /api/auth/refresh-tokens with your refresh token to obtain a new access token pair

Issue: 403 Email not verified

Cause: User registered but did not verify their email OTP

Resolution: Call POST /api/auth/resend-otp, then submit the OTP to POST /api/auth/verify-otp

Issue: Account locked — 423 response

Cause: 5 or more consecutive failed login attempts

Resolution: Wait 15 minutes, then retry. The error message includes the exact remaining wait time

Issue: CSV upload returns 422 validation failed

Cause: CSV is missing required columns (group, selected, total) or contains negative / invalid values

Resolution: Ensure all rows have group name, non-negative selected count $\leq$ total count, and total > 0

Issue: Finding approval blocked — 400 response

Cause: Governance gate: missing evidence, criteria, or recommendation

Resolution: Add at least one evidence item (POST /api/findings/:id/evidence) and ensure criteria + recommendation fields are filled

Issue: Evidence upload returns 503

Cause: CLOUDINARY_URL environment variable not set on the server

Resolution: Contact the platform administrator to configure the Cloudinary integration

Issue: Evidence upload returns 415

Cause: File type not permitted

Resolution: Accepted types: PDF, Word (.doc/.docx), Excel (.xls/.xlsx), CSV, plain text (.txt), PNG, JPEG. Re-save or convert the file

Issue: Evidence upload returns 413

Cause: File exceeds the 10 MB size limit

Resolution: Compress or split the file and re-upload

Issue: Handbook upload: 422 — could not extract text

Cause: PDF is a scanned image without embedded text layer

Resolution: Run the document through OCR software (e.g. Adobe Acrobat Pro) to embed a text layer before uploading

Issue: AI fields are empty after creating a finding

Cause: OPENAI_API_KEY is not configured — AI draft is skipped silently

Resolution: Confirm OPENAI_API_KEY is set in the server environment. Use POST /api/findings/:id/regenerate-draft once configured

Issue: Deletion request returns 409

Cause: A pending deletion request already exists for this audit

Resolution: The director must action (approve or reject) the existing request before a new one can be submitted

Issue: Deletion request returns 400: director not found

Cause: The directorId provided does not belong to a user with the director role in this organisation

Resolution: Call GET /api/users/directors first to obtain valid director IDs, then resubmit

Issue: Pay equity upload returns 415

Cause: File format not supported

Resolution: Accepted formats: CSV, Excel (.xlsx, .xls), PDF with embedded text, DOCX. Scanned PDFs without text layers are not supported

10 Frequently Asked Questions

Q: Can I use the platform without OpenAI configured?

A: Yes. All core features work without OPENAI_API_KEY. AI-assisted fields (finding criteria/recommendation drafts, pay equity report narratives, position document analysis) will be empty or use rule-based fallback text. You can fill these fields manually.

Q: What happens to the audit data when an audit is deleted?

A: The audit record is removed from the database. However, a full AuditDeletionRequest record (including an auditSnapshot preserving all audit metadata) and two ActivityLog entries are retained indefinitely for compliance purposes.

Q: Can two users from different companies see each other's data?

A: No. All data is isolated by organizationId — a UUID assigned when the first user from a company registers. Every database query includes an organizationId filter enforced at the controller level.

Q: How do I add a new user to my organisation?

A: Users join an organisation by registering with the same companyName as an existing user. The system automatically assigns them the organisation's UUID. An admin must then update their role if they need more than viewer access.

Q: What does the 'findingId' field in finding responses mean?

A: findingId is an alias for the finding's _id field. It is included explicitly so you can copy it directly into evidence endpoint URLs without having to know that _id and findingId are the same value.

Q: Can I upload the same CSV twice?

A: Yes, but each upload creates a new AdverseImpactAnalysis record and new flags. There is no duplicate detection. Review the flag list before uploading again to avoid duplicating existing flags.

Q: Why does my finding show as 'new' status?

A: new is the default status on creation. Advance it to under_review when you are ready to submit it for evaluation.

Q: How are handbook chunks used in AI draft generation?

A: When a finding is created, the system searches all 'ready' handbooks in the organisation using a keyword match against the finding's observation text. The top 2 matching chunks per handbook (up to 3 total) are passed to the AI as context for drafting criteria.

Q: Can I re-generate the AI draft after editing the observation?

A: Yes. Use POST /api/findings/:id/regenerate-draft. This re-runs the AI with the current observation and the latest handbook content. If the finding is in 'approved' or 'closed' status, regeneration is blocked.

Q: Does the system send notifications to the director when a deletion request is submitted?

A: Currently, the system does not send email notifications for deletion requests. The director must check their deletion request queue (GET /api/audits/deletion-requests) periodically. Email notifications are planned for a future release.

Q: What is the maximum number of audits I can have?

A: There is no hard limit imposed by the application. MongoDB Atlas cluster capacity and the organisation's subscription plan are the practical constraints.

Q: How do I access the interactive API documentation?

A: Navigate to /api/docs on the deployed server (e.g. <https://trimerge-comply.onrender.com/api/docs>). The Swagger UI lists all endpoints, schemas, and allows you to try requests directly from the browser.

11 Security & Compliance

Control	Implementation
Password hashing	bcryptjs with configurable rounds (default 10). Passwords never stored in plain text
Access tokens	JWT signed with JWT_SECRET, 15-minute TTL. Stateless — no server-side session store
Refresh tokens	SHA-256 hashed before database storage. Raw value returned to client only once
Token rotation	Each /refresh-tokens call issues a new pair, invalidating the previous refresh token
Logout	Refresh token hash cleared in database; subsequent refresh attempts fail
Account lockout	5 failed login attempts triggers a 15-minute lockout. Counter resets on success
OTP hashing	All OTPs are bcrypt-hashed before storage. Plain text OTP never persisted
Password change	Requires current password + email OTP confirmation. New password stored as pending until OTP verified
Verified-only access	All protected routes check isVerified = true. Unverified users cannot access the API

Control	Implementation
HTTPS enforcement	Render enforces TLS. HTTP connections are redirected
HTTP security headers	helmet sets X-Content-Type-Options, X-Frame-Options, Strict-Transport-Security, CSP, etc.
NoSQL injection protection	express-mongo-sanitize strips \$ and . from all request inputs
HTTP parameter pollution	hpp prevents duplicate query parameters from bypassing validation
Global rate limiting	500 requests per 15-minute window per IP across all routes
Auth rate limiting	30 requests per 15-minute window per IP on /api/auth/* endpoints
CORS	Restricted to configured CORS_ORIGIN + localhost:3000 + production Render domain
Body size limits	JSON body: 10 KB · File uploads: 10 MB enforced in Express middleware
Input validation	express-validator applied on auth routes; controller-level guards on all others

Control	Implementation
Role-based access control	requireRole() middleware on every route. Role checked from JWT user object
Multi-tenant isolation	Every database query includes organizationId from req.user — users cannot access other orgs' data
Owner-only enforcement	Analysts can only update audits they created; only delete evidence they added (unless manager+)
Sensitive field exclusion	password, refreshToken, otpCode, resetToken excluded by default in all User queries
Director scoping	Deletion requests visible only to the director they were routed to (admins see all)

The ActivityLog model captures every material action performed on the platform. Entries are immutable — there are no update or delete endpoints on ActivityLog. The following actions are logged:

Action	Trigger
audit_created	Audit created
audit_updated	Audit fields modified (with before/after values)
audit_deleted	Audit deleted (either path)
deletion_requested	Deletion request submitted by analyst/manager/reviewer
deletion_approved	Director approves deletion request
deletion_rejected	Director rejects deletion request
flag_decided	Flag marked reviewed or dismissed
flag_assigned	Flag assigned to an analyst
finding_created	Finding created
finding_updated	Finding fields modified (with change delta)
finding_status_changed	Finding status advanced
evidence_added	Evidence item attached to finding (text or file)
evidence_removed	Evidence item deleted
handbook_uploaded	Handbook indexed into the system
handbook_deleted	Handbook removed

12 Administrator Guide

All user management is performed via API calls authenticated as an **admin** role account. There is no separate admin console; the Swagger UI at `/api/docs` provides a convenient interface.

Task	Endpoint	Notes
List all org users	GET <code>/api/auth/users</code>	Returns all users with matching organizationId
Change a user's role	PATCH <code>/api/auth/users/:id/role</code>	Body: { role: 'analyst' }. Admin only. Same org.
View profile	GET <code>/api/auth/me</code>	Returns own profile
Update display name	PATCH <code>/api/auth/change-name</code>	Body: { name: '...' }

1. Log in as an admin account and obtain an access token
2. Call GET `/api/auth/users` to list all users in your organisation
3. Identify the user whose role needs to change and note their `_id`
4. Call PATCH `/api/auth/users/:id/role` with body { "role": "analyst" } (or whichever role is required)
5. The user's role is updated immediately; their next API request will use the new role

Note on New User Onboarding

New users register themselves via POST `/api/auth/signup`. They are assigned the 'viewer' role by default and must verify their email before they can log in. An admin must then update their role if they need analyst, reviewer, manager, director, or admin access.

Task	How To	Frequency
Review pending deletion requests	GET <code>/api/audits/deletion-requests?status=pending</code> (as director/admin)	Weekly or as needed
Audit activity log	GET <code>/api/activity</code> — filter by action, targetType, or date range	Monthly for compliance review
Monitor flag backlog	GET <code>/api/flags?status=open</code> — review open flags	Weekly
Prune old handbooks	DELETE <code>/api/handbooks/:id</code> (director/admin) when policy docs are superseded	When policies change
Export audit data	GET <code>/api/audits/export</code> or GET <code>/api/dashboard/export</code> for CSV snapshots	Per engagement close or quarterly

13 Data Dictionary

User

Field	Type	Description
_id	ObjectId	Primary key
email	String	Unique login identifier, lowercased
name	String	Display name
companyName	String	Used to group users into an organisation
role	Enum	admin director manager analyst reviewer viewer
organizationId	String (UUID)	Org isolation key. All queries scoped to this value
isVerified	Boolean	True after OTP email verification. Login blocked until true
isActive	Boolean	False = soft-deactivated. Login blocked
lastLoginAt	Date	Timestamp of last successful login
failedLoginAttempts	Number	Counter reset on success; triggers lockout at 5
lockedUntil	Date	Account locked until this timestamp after excessive failures

Audit

Field	Type	Description
_id	ObjectId	Primary key
name	String	Required, max 100 chars
description	String	Optional narrative, max 500 chars
status	Enum	draft processing completed flagged
organization	String	Organisation or department name
clientName	String	Client engagement name
auditType	String	Classification string (free text)
organizationId	String	Org isolation key
createdBy	Ref: User	User who created this audit

Flag

Field	Type	Description
_id	ObjectId	Primary key
auditId	Ref: Audit	Present on audit-linked flags
uploadId	Ref: AdverseImpactAnalysis	Present on CSV-based flags
severity	Enum	low medium high critical
status	Enum	open reviewed dismissed
group	String	Demographic group that was flagged
referenceGroup	String	Highest-selecting comparison group
selectionRate	Number	Fraction selected in this group
impactRatio	Number	group rate / reference rate (< 0.80 = flagged)
testType	Enum	four_fifths fisher_exact chi_square adverse_impact
pValue	Number	Statistical significance value
assignedTo	Ref: User	Analyst assigned to investigate
results	Mixed	Detailed statistical results from CSV processing

Finding

Field	Type	Description
_id	ObjectId	Primary key; also exposed as findingId alias
auditId	Ref: Audit	Parent audit
flagId	Ref: Flag	Optional linked flag
observation	String	Required — what the analyst observed
risk.level	Enum	low medium high critical
risk.description	String	Context for the risk assessment
criteria	String	Regulatory/policy basis for the finding (AI-drafted or manual)
recommendation	String	Corrective action recommendation (AI-drafted or manual)
status	Enum	new under_review additional_info_required approved rejected closed
aiDrafted	Boolean	True if criteria/recommendation were AI-generated
handbookReference	Object	Handbook excerpt used to ground the AI draft

Field	Type	Description
assignedTo	Ref: User	Analyst working on this finding
reviewedBy	Ref: User	Director/reviewer who made the final decision
reviewedAt	Date	Timestamp of approval or rejection

Evidence

Field	Type	Description
_id	ObjectId	Primary key
findingId	Ref: Finding	Parent finding
auditId	Ref: Audit	Denormalised for query efficiency
type	Enum	document statistical_result interview_note policy_excerpt data_extract observation_note
source	Enum	manual flag payequity adverse_impact position handbook
title	String	Required, max 200 chars
description	String	Short summary
content	String	Full text content for non-file evidence
file.fileName	String	Original filename (file-backed evidence only)
file.fileUrl	String	Cloudinary secure URL
file.mimeType	String	MIME type of the uploaded file
file.sizeBytes	Number	File size in bytes
interviewee	String	Name of interviewee (interview_note type only)
interviewDate	Date	Date of interview
collectedBy	Ref: User	Analyst who added this evidence

AuditDeletionRequest

Field	Type	Description
_id	ObjectId	Primary key
auditId	Ref: Audit	Audit being requested for deletion
auditSnapshot	Mixed	Full copy of audit fields at request time — retained after deletion

Field	Type	Description
requestedBy	Ref: User	User who submitted the deletion request
deletionNotes	String	Mandatory justification (min 10 chars)
directorId	Ref: User	Director selected to approve or reject
status	Enum	pending approved rejected
reviewedBy	Ref: User	Director who actioned the request
reviewedAt	Date	Timestamp of approval or rejection
approvalNotes	String	Mandatory director rationale (min 10 chars)

ActivityLog

Field	Type	Description
_id	ObjectId	Primary key
targetType	Enum	audit flag finding handbook position payequity
targetId	ObjectId	ID of the affected record
auditId	Ref: Audit	Denormalised audit reference for filtering
action	Enum	One of 19 defined action types (see Section 11.4)
performedBy	Ref: User	User who performed the action
organizationId	String	Org isolation key
details	Mixed	Action-specific payload (before/after values, notes, etc.)

14 Glossary

Adverse Impact

A substantially different rate of selection in employment decisions that works to the disadvantage of members of a protected group (race, gender, national origin, etc.)

Audit

The top-level container in TriMerge Comply representing a compliance engagement for a specific client or department

bcrypt

A password hashing function used to securely store passwords. A bcrypt hash is computationally expensive to reverse

Cloudinary

A cloud-based media storage and delivery service used by TriMerge Comply to host uploaded documents and evidence files

Evidence

A piece of information attached to a finding to support its conclusion. Can be text (notes, excerpts) or a file (PDF, spreadsheet, image)

Finding

A formal compliance conclusion documented within an audit. Must pass through a defined status machine and governance gate before approval

Flag

An automatically generated indicator that a demographic group's selection rate falls below the EEOC four-fifths threshold

Four-Fifths Rule

An EEOC guideline stating that a selection rate for a protected group that is less than four-fifths (80%) of the rate for the group with the highest selection rate is evidence of adverse impact

Governance Gate

A server-side enforcement check that blocks a finding from being approved unless criteria, recommendation, and at least one evidence item are present

Impact Ratio

The selection rate of a demographic group divided by the selection rate of the highest-selecting group. A value below 0.80 triggers a flag

JWT (JSON Web Token)

A compact, URL-safe token format used to convey authentication claims between the client and server

Mailgun

The third-party email delivery service used to send OTP codes and password reset links

Multi-tenancy

An architecture where a single platform instance serves multiple organisations, with complete data isolation between them

OLS Regression

Ordinary Least Squares regression — a statistical method used in pay equity analysis to estimate compensation gaps after controlling for legitimate factors

OTP (One-Time Password)

A single-use numeric code sent via email to verify identity for account verification and password changes

organizationId

A UUID (Universally Unique Identifier) assigned to a group of users sharing the same companyName. All data is filtered by this value to enforce multi-tenant isolation

Pay Equity

The principle that employees receive the same compensation for the same work, regardless of demographic characteristics

Position Document

An uploaded job description or job posting reviewed against government compliance standards

Severity

A classification of flag urgency: low, medium, high, or critical — determined by the impact ratio and statistical test results

SME Reviewer

A subject-matter expert who reviews and validates flags and findings created by analysts